CYBERSECURITY INTERNSHIP

WEEK 7 ASSIGNMENT

VAPT: WEB APPLICATION TESTING WITH BURP SUITE

INTERNSHIP REPORT

Submitted by: Deepashree.C

Role: Cybersecurity Intern

Week: Week 7

SIN: DG/SEPTEMBER/CYBER/254

Submitted to: DG Interns Hub

Topics Covered

- Burp Suite setup and HTTP/HTTPS traffic interception
- Web application reconnaissance and attack surface mapping
- SQL Injection, Reflected and Stored XSS, and authentication testing
- Parameter tampering, directory and endpoint discovery
- VAPT vulnerability analysis, risk assessment and remediation

1. Executive Summary

This report documents a Week 7 cybersecurity internship exercise focused on Vulnerability Assessment and Penetration Testing (VAPT) of the Damn Vulnerable Web Application (DVWA) in a controlled local lab. Burp Suite was used as an intercepting proxy to inspect HTTP/HTTPS traffic, map application endpoints, and manually test common web application weaknesses. The presentation describes testing activities for SQL Injection, reflected and stored Cross-Site Scripting (XSS), authentication and session handling, parameter tampering, and endpoint discovery.

The findings table in the source presentation lists potential vulnerability categories and recommended remediations. The slides do not provide severity scores or enough evidence to assign confirmed exploitability to every category; therefore, this report preserves the source presentation's scope and observations without inventing additional results.

2. Objectives and Scope

2.1 Objectives

- Configure Burp Suite as an intercepting proxy.
- Intercept and analyze HTTP/HTTPS traffic from DVWA.
- Identify authentication requests, session cookies, and input parameters.
- Map DVWA endpoints and identify its attack surface.
- Perform manual vulnerability testing using Burp Repeater.
- Test for SQL Injection, Cross-Site Scripting (XSS), and parameter tampering.
- Document vulnerabilities with impact and remediation recommendations.

2.2 Scope and Authorization

Target: DVWA hosted in a controlled local laboratory.

Testing areas: authentication, input validation, SQL Injection, XSS, session handling, and endpoint discovery.

Restriction: all testing was performed only against the authorized educational lab application.

3. Burp Suite Setup and HTTP Interception

Burp Suite was configured as an interception proxy. Firefox was set to use proxy host 127.0.0.1 and port 8080, and proxy interception was enabled. Burp's CA certificate was installed in Firefox to support HTTPS traffic analysis.

- Example intercepted request: GET /dvwa/ HTTP/1.1
- Host: 127.0.0.1
- Observation: Burp Suite intercepted and analyzed browser requests before forwarding them to the local DVWA application.

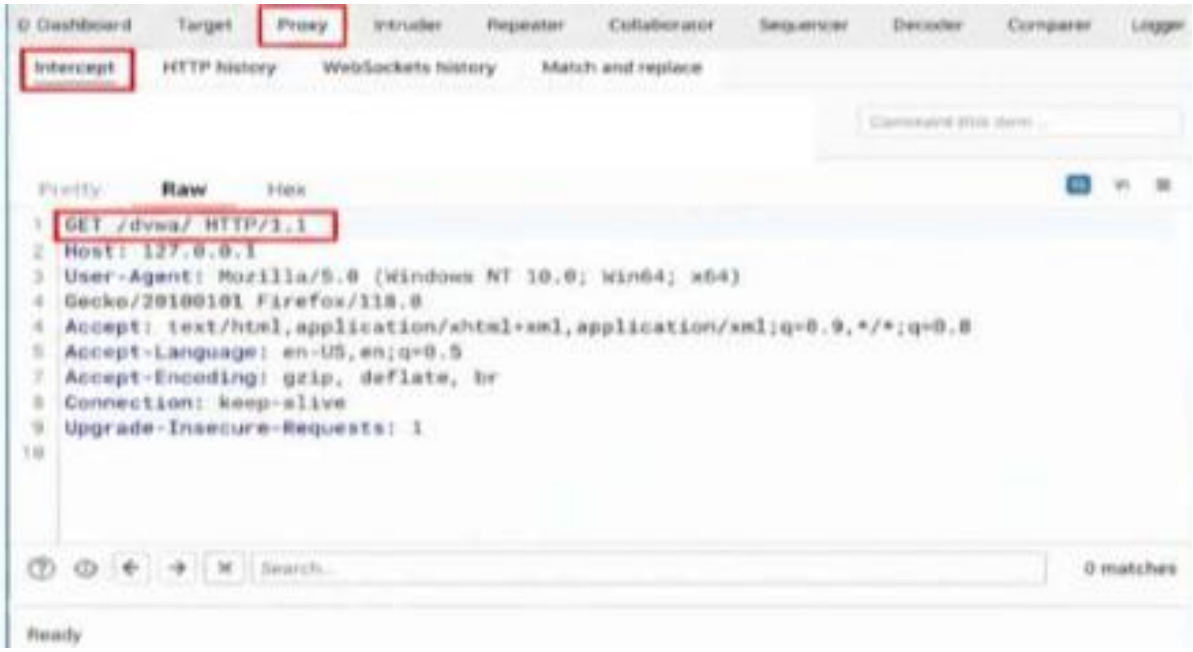


Figure 3.1: Image from the original Week 7 presentation

4. HTTPS Certificate and Login Request Analysis

The Burp Suite CA certificate was installed in Firefox so HTTPS traffic could be inspected within the authorized lab. The DVWA login exchange was examined for the HTTP method, login endpoint, username and password parameters, headers, response status, and session cookie.

- Observation: the captured login exchange illustrated how DVWA processes authentication requests and manages session cookies after a successful login.

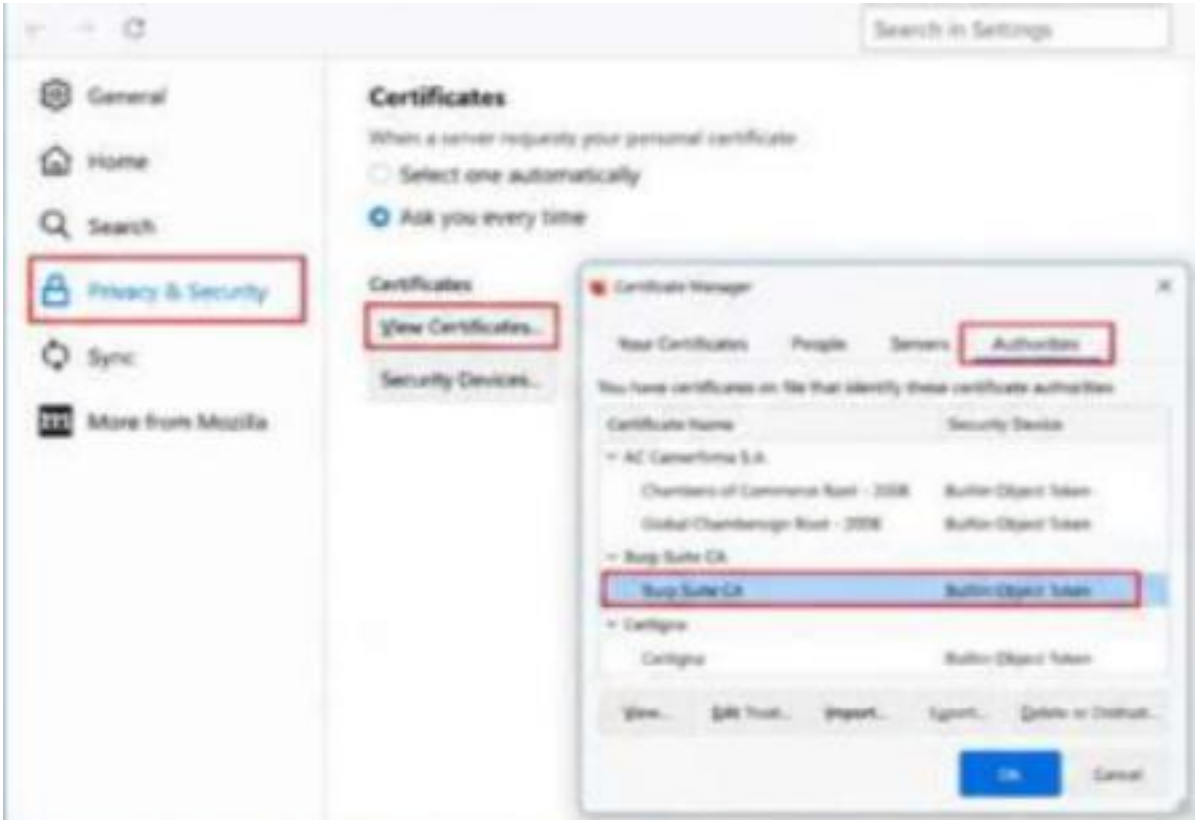


Figure 4.1: Image from the original Week 7 presentation

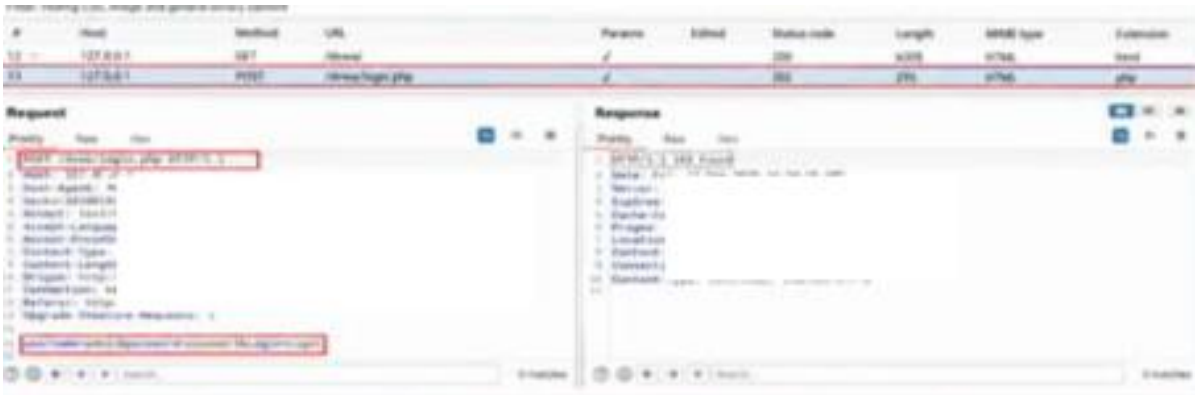


Figure 4.2: Image from the original Week 7 presentation

5. Reconnaissance and Application Mapping

Burp Suite Proxy and the Target site map were used to explore the DVWA application. The mapping process identified login and logout pages, vulnerability modules and input fields, GET and POST parameters, application directories, static resources, and accessible endpoints.

- Example GET parameter: id=1
- Example POST parameters: username=admin, password=password
- Observation: mapping highlighted user-input points and potential areas for further assessment.

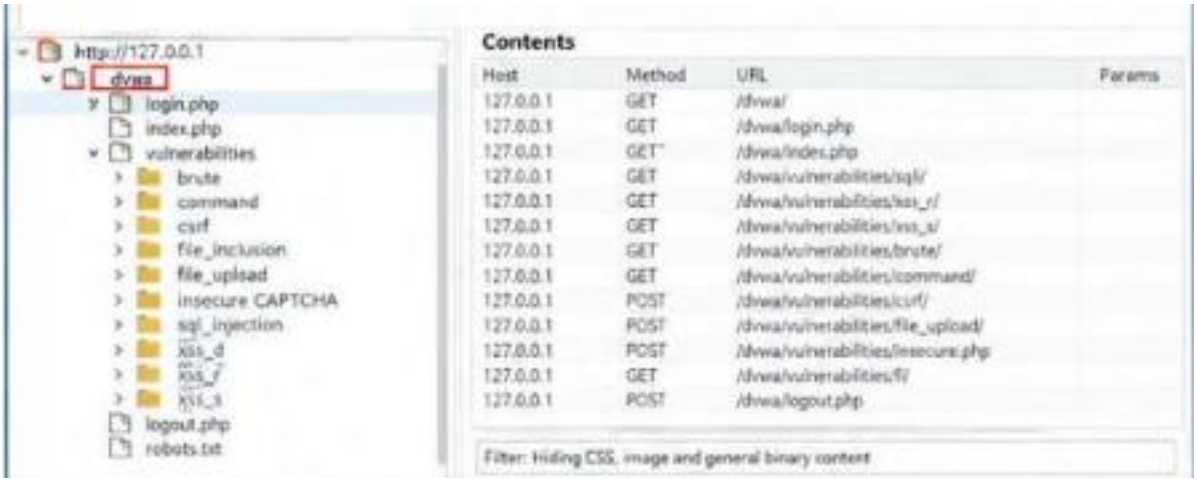


Figure 5.1: Image from the original Week 7 presentation

6. SQL Injection Testing

The DVWA SQL Injection module was opened and a valid input was submitted. The request was intercepted and sent to Burp Repeater, where the input parameter was modified with a test string. Server responses were compared to assess whether the input influenced the database query.

- Test payload: ' OR 1=1--
- Potential impact: depending on configuration, SQL Injection may expose database information or enable unauthorized data access or modification.
- Remediation: use parameterized queries and prepared statements, apply server-side input validation, and restrict database permissions according to least privilege.
- Observation: response differences helped assess whether input was improperly incorporated into SQL queries.

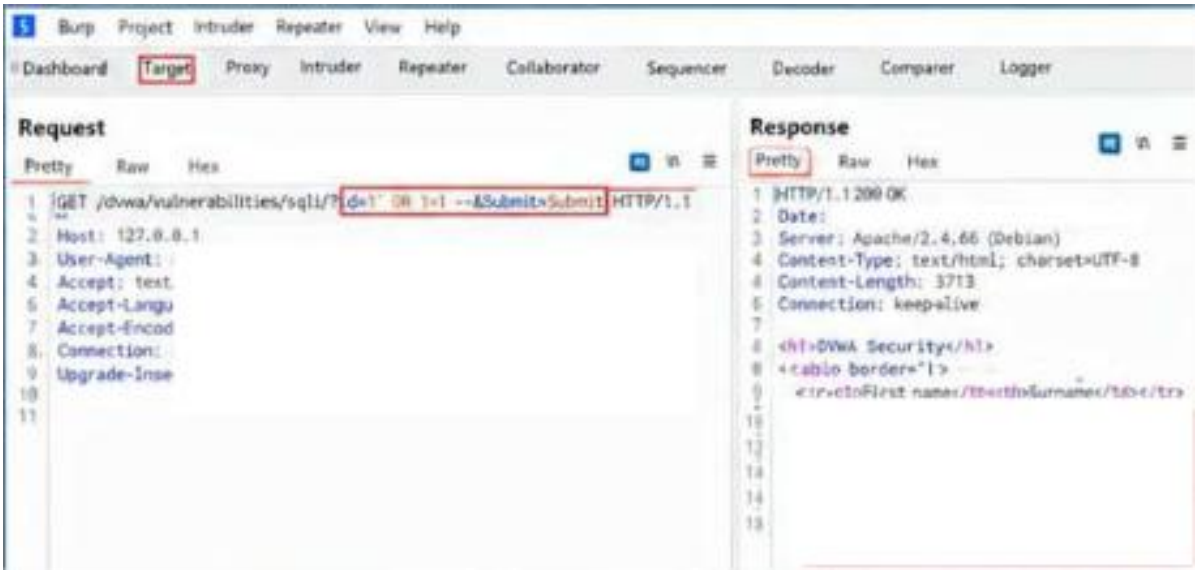


Figure 6.1: Image from the original Week 7 presentation

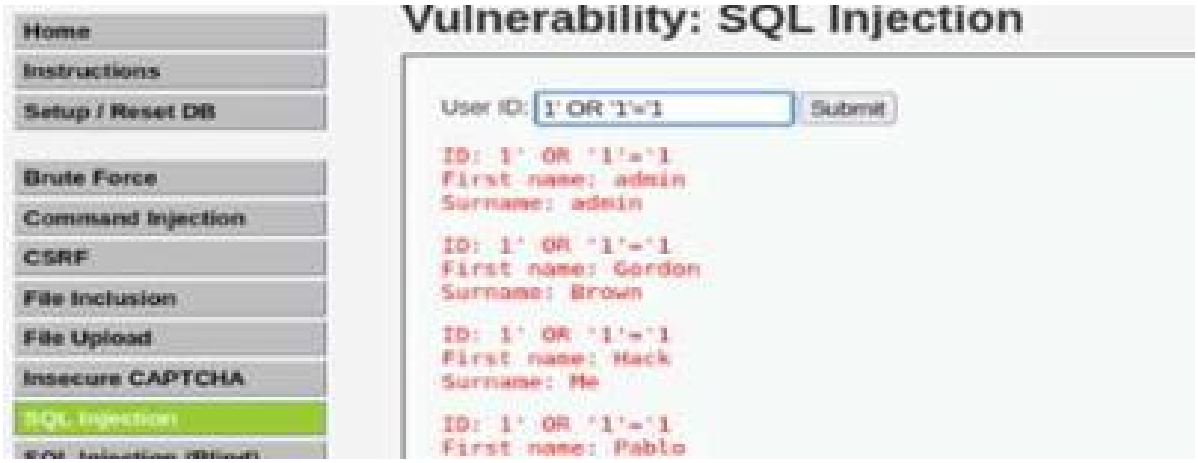


Figure 6.2: Image from the original Week 7 presentation

7. Cross-Site Scripting (XSS) Testing

The DVWA Reflected and Stored XSS modules were tested using Burp Suite. Input parameters were modified in Repeater and a proof-of-concept payload was submitted. The test checked whether input was reflected or stored and executed unsafely in the browser.

- Test payload: <script>alert(1)</script>
- Remediation: apply output encoding, validate input, and implement a Content Security Policy (CSP).
- Observation: testing assessed whether user input could execute as JavaScript in the browser.



Figure 7.1: Image from the original Week 7 presentation



Figure 7.2: Image from the original Week 7 presentation

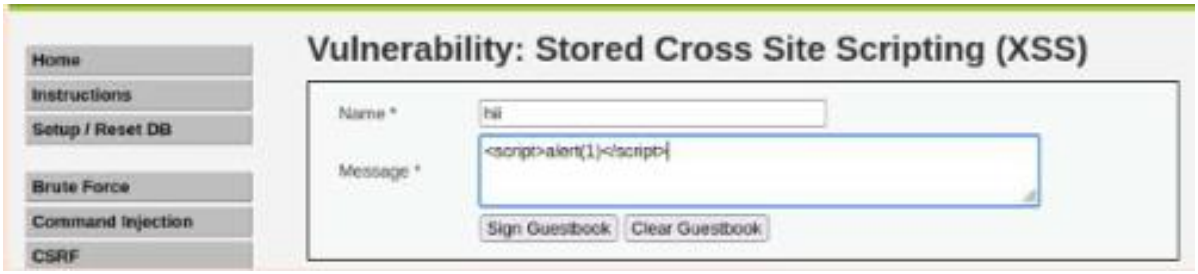


Figure 7.3: Image from the original Week 7 presentation

8. Authentication, Authorization and Parameter Tampering

Authorization testing used Burp Suite HTTP History and Repeater to check access to restricted resources. The process involved capturing an authenticated request, sending it to Repeater, modifying request values or using a lower-privileged test account, and comparing server responses to verify access restrictions.

- Areas examined: protected URLs, user roles and privileges, unauthorized access, and server responses.
- Security principle: the server must verify user permissions before allowing access to protected resources.

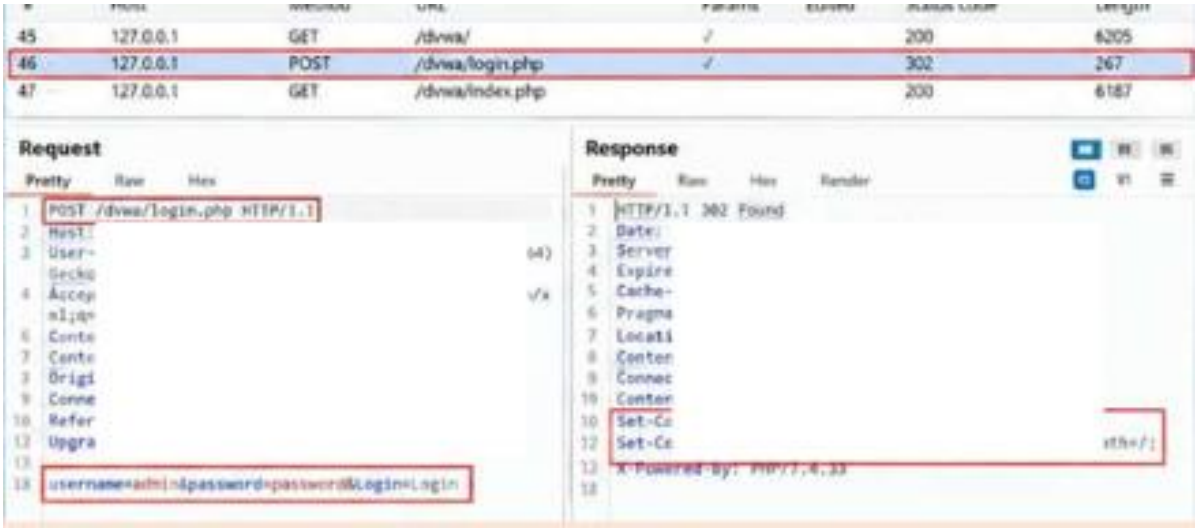


Figure 8.1: Image from the original Week 7 presentation

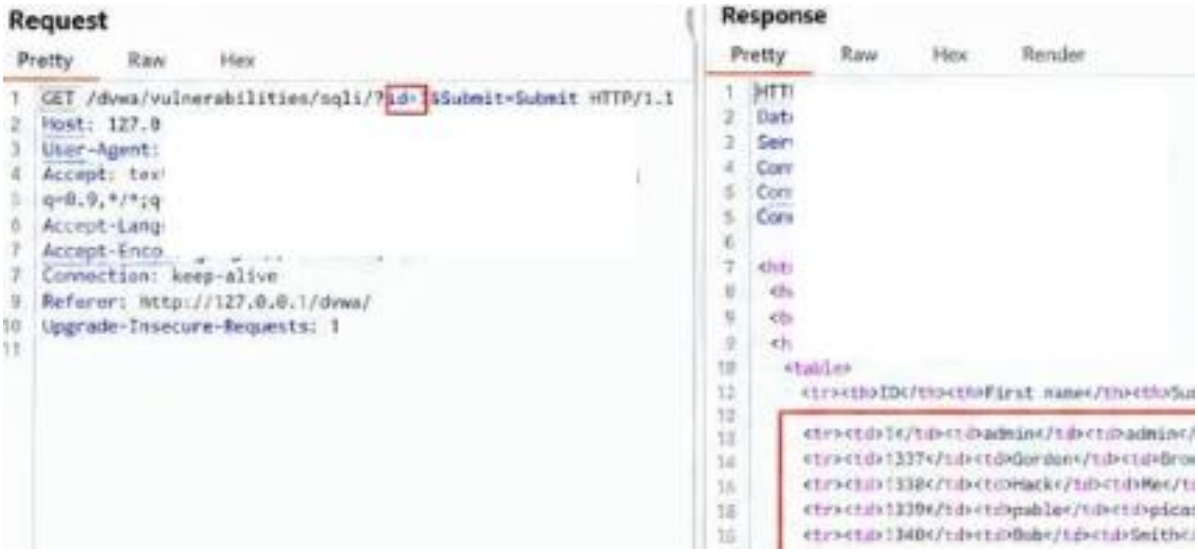


Figure 8.2: Image from the original Week 7 presentation

9. Session Management and Endpoint Discovery

The presentation describes examining session cookies and logout behavior through Burp Suite HTTP History. Testing included identifying the session cookie and its attributes, checking session expiration, logging out, and replaying a previous authenticated request to verify invalidation. The application site map was also used for directory and endpoint discovery.

- Security importance: proper session management helps prevent unauthorized access through stolen, expired, or invalid session cookies.
- Endpoint discovery helps identify exposed resources that may require access restrictions.

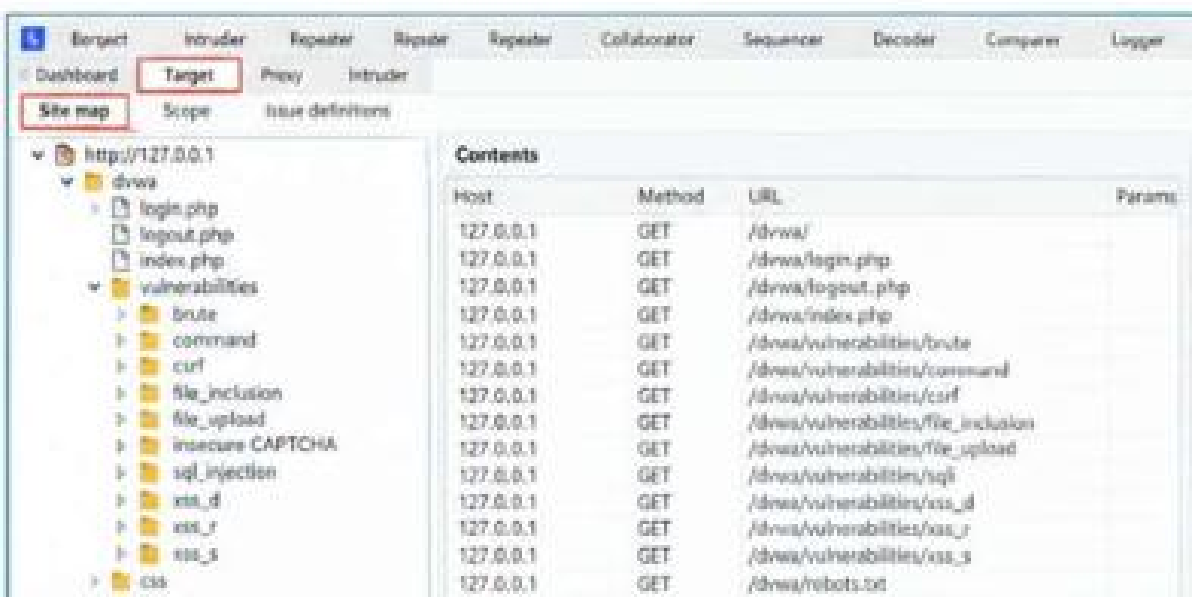


Figure 9.1: Image from the original Week 7 presentation

10. VAPT Findings and Remediation

The following table reproduces the finding categories, testing methods, and remediation guidance listed in the source presentation.

Finding	Testing Method	Recommended Remediation
SQL Injection	Burp Repeater	Use parameterized queries.
Reflected XSS	Burp Repeater + Browser	Apply output encoding.
Stored XSS	Burp + Browser	Sanitize input and encode output.
Authentication/Session Issues	HTTP History	Secure authentication and session handling.
Parameter Tampering	Burp Repeater	Enforce server-side validation and authorization.
Endpoint Discovery	Target/Site Map	Restrict access to sensitive resources.

11. Conclusion

The exercise demonstrated how client-side requests can be intercepted and analyzed using Burp Suite. It strengthened understanding of HTTP methods, parameters, headers, and server responses, while emphasizing secure coding practices throughout application development. Appropriate authentication and authorization, input validation, output encoding, least-privilege database and user permissions, and careful handling of error messages help protect confidential information and reduce injection risks. Findings should be recorded with their testing methods, potential impact, and remediation recommendations, followed by retesting after fixes. The exercise provided practical experience in web application security testing using an intentionally vulnerable environment and reinforced the value of continuous security assessment.

12. Limitations

This report is based on the content and embedded figures in the supplied Week 7 PowerPoint. The source slides do not include a detailed severity rating, CVSS scores, complete request/response logs, or evidence for every finding. Accordingly, no additional technical results or risk ratings have been fabricated.